
What is AWS Cognito?

AWS Cognito is a **serverless identity management service** that provides **user authentication, authorization, and user management** for your web and mobile apps.

 It helps you **sign up, sign in, and secure access** to your applications with built-in user directories or social login (Google, Facebook, etc.).

Core Components of AWS Cognito

1 User Pools (Authentication)

A **user directory** to handle **sign-up/sign-in** functionality.

 Manages:

- Usernames & passwords
- Multi-Factor Authentication (MFA)
- Account verification (email/SMS)
- Tokens (JWT – ID, Access, Refresh)

 Used in: Web/mobile frontends for user authentication.

2 Identity Pools (Authorization)

Also known as **Federated Identities**, it allows users to **access AWS resources** (like S3, DynamoDB) **after authentication**.

 Supports:

- Cognito User Pools

- Social IdPs (Facebook, Google)
- SAML providers (ADFS, Azure AD)
- Anonymous (unauthenticated) guest access

🔧 Used in: Mapping authenticated users to IAM roles for **secure AWS access**.

📁 **Cognito Architecture Summary**

User signs in (via User Pool or Social Login)



Cognito issues JWT tokens (ID, Access, Refresh)



Tokens are exchanged with Identity Pool



Cognito Identity Pool assigns IAM Role



User gets temporary AWS credentials



Access AWS services (e.g., S3, API Gateway)

📄 **Types of Tokens in Cognito**



Token Type



Description



ID Token

Contains user profile (name, email, etc.)



Access Token

Used to authorize API requests



Refresh Token

Used to get new ID/Access tokens

All are JWTs signed with JSON Web Signature (JWS).

Key Features

 Feature	Description
 Social Login	Sign in with Google, Facebook, Apple, Amazon
 Custom UI	Customizable sign-in/sign-up hosted UI
 Multi-Factor Authentication	SMS, TOTP supported
 Token Management	Secure token issuance and rotation
 Fine-grained Access	Role-based control via Identity Pool
 Email/SMS Verification	Send confirmation and recovery messages
 Triggers with Lambda	Customize workflows (pre-signup, post-confirmation, etc.)

Cognito Lab: Sign Up & Secure S3 Access

Goal:

- Users sign up via Cognito User Pool
- Authorized users access private S3 files via Cognito Identity Pool

Step-by-Step:

1. Create a User Pool

- Go to Cognito → **User Pools**
- Create new pool → Enable email signup/login
- Enable email verification
- Choose app client (no client secret if for frontend)

2. Create a Domain

- In **App integration**, choose “App client settings”
- Set up a **Cognito-hosted UI**
- Enable login/logout URLs

3. Test Sign Up

- Use the hosted UI
- Sign up and confirm via email
- Cognito issues tokens

4. Create an Identity Pool

- Go to **Cognito** → **Federated Identities**
- Link the **User Pool** as an **authentication provider**
- Define **IAM roles** for authenticated/unauthenticated users

5. Set up S3 Access

- Create an S3 bucket (e.g., **cognito-demo-files**)
- Update IAM role (for Identity Pool) to allow S3 **GetObject** on bucket

6. Use AWS SDK in App

- Use Cognito tokens to authenticate
- Get temporary AWS credentials

- Access S3 securely!

Security Best Practices

-  Use **MFA (TOTP or SMS)**
-  Rotate refresh tokens
-  Set token expiration policy (e.g., 1hr for Access Tokens)
-  Add custom validation using **Lambda triggers**
-  Monitor with **CloudWatch** and **CloudTrail**

Integration Options

 Integration	 Use Case
 API Gateway	Secure REST APIs
 S3	Control object access via Identity Pool
 Lambda	Pre/post user auth workflows
 IAM Roles	Fine-grained AWS access control
 OpenID Connect	Integrate with 3rd party auth

Summary Table

 Concept	 Description
 User Pool	Handles sign-up/sign-in & JWT token issuance

 Identity Pool	Exchanges tokens for AWS credentials
 Tokens	ID, Access, Refresh (JWT)
 Federation	Supports Google, Facebook, Apple, SAML
 Security	MFA, password policies, triggers
 Customization	Lambda hooks, hosted UI, branding

Common Interview Questions

1.  What's the difference between User Pool and Identity Pool?
 2.  How does Cognito integrate with S3 or API Gateway?
 3.  What are the token types issued by Cognito?
 4.  How do you secure Cognito with MFA?
 5.  Can you use Cognito with on-premise AD?
-